UC-008 Sign in and read within scope

Sign in and read within scope

Use case, reversed from the implementation at 0.3.0. Draft.

The solution in one sentence

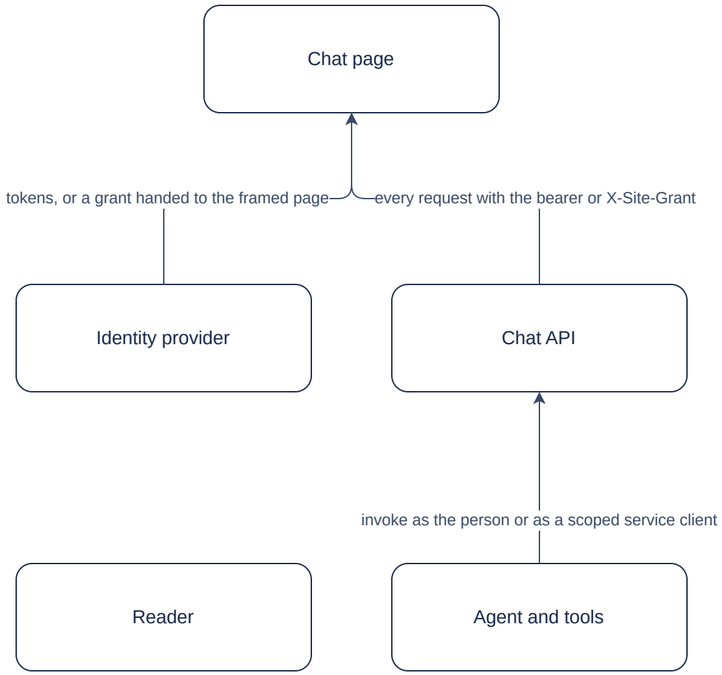
A reader signs in, with the deployment's own sign-in or through the website that hosts the store, and sees only the content their scope allows, with the same identity checked at the page, the API, the agent and the tools, so that private sources never reach a public reader whatever a model asks for.

A chat that acts as a service sees everything and leaks by prompt. The person's own identity has to travel to the data.

What is different afterwards

A person in the private-readers group, with a private role, or an application with the private scope reads private facts, passages, rows and documents; everyone else reads public ones, and the interceptor makes that true for every tool call.

The solution on one page



Generated from the Participants and Interactions tables with the model skill; `components.drawio` is the source.

Participants

Participant	Role in this use case	Kind
01 Reader	Signs in and reads	actor
02 Chat page	Code flow with PKCE, or the host's grant	solution
03 Identity provider	Cognito, or the host website's keys	external
04 Chat API	Verifies, reads sub and groups or roles, filters	solution
05 Agent and tools	The same token; the interceptor sets the scope	solution

Interactions

Interface	Provider	Consumer	Purpose
IF-01	03 Identity provider	02 Chat page	tokens, or a grant handed to the framed page
IF-02	04 Chat API	02 Chat page	every request with the bearer or X-Site-Grant
IF-03	05 Agent and tools	04 Chat API	invoke as the person or as a scoped service client

Catalogue Mapping

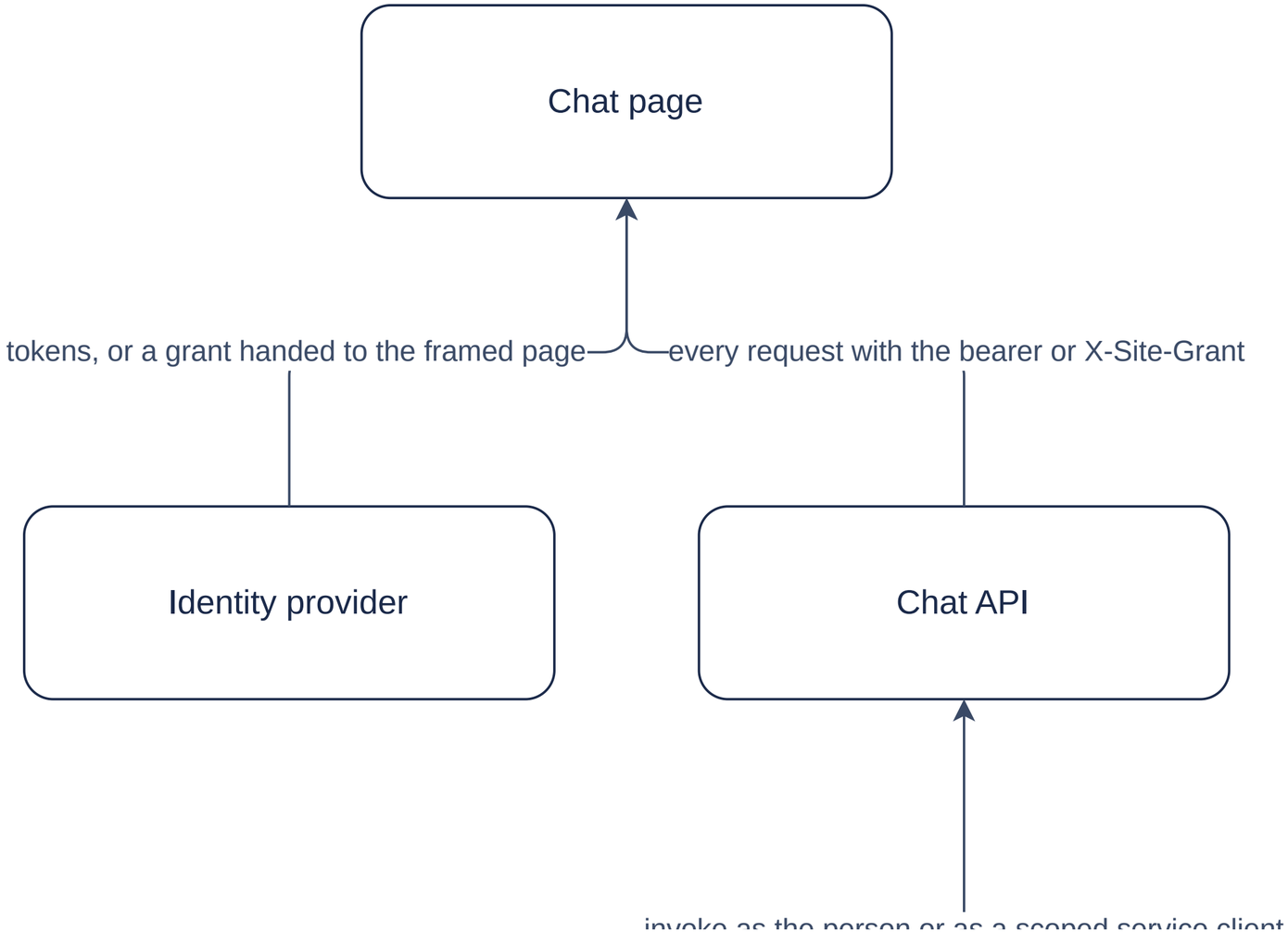
What each local participant stands for in the catalogue: an actor or an external system is a gap by design (no artefact of this catalogue realises a person or a vendor); a solution participant realises or partly realises a building block.

Local ID	Maps To	Relationship
01	gap	gap
02	ABB-018 Chat page	realises
03	ABB-020 Identity	partial
04	ABB-019 Chat API	partial
05	ABB-027 Call interceptor	partial

The flow

UC-008 Sign in and read within scope: scenarios

S1 Main success scenario, hosted sign-in | S2 Sign-in through a host website



S1 Main success scenario, hosted sign-in

◀ Prev | Next ▶ | ▶ Play

Restart | Zoom to step: on

Arrow keys step, space plays

1. sign in through the hosted UI with PKCE
2. send the access token on every request
3. pass the same token; the Runtime and the Gateway verify it; the interceptor writes caller_private
4. show only what the scope allows; sign a document link after the check

Data and measures

- Token claims: sub, groups, scope; grant claims: sub, roles
- Scope per source, per table